

Clase 187 — Detección basada en MITRE ATT&CK

Parte: 8 — Blue Team, detección y SOC · Fuente: MITRE ATT&CK — framework de tácticas y técnicas adversarias 🕒 Duración estimada: 110 min · Nivel: Intermedio

🎯 Objetivo

Usar MITRE ATT&CK como columna vertebral de la detección: hablar de comportamiento adversario con un vocabulario común, mapear tus detecciones a técnicas, medir cobertura con ATT&CK Navigator y priorizar qué detectar usando la pirámide del dolor. Dejarás de perseguir IOCs volátiles para detectar TTPs (tácticas, técnicas y procedimientos) que al atacante le duele cambiar.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Navegar** la matriz ATT&CK (tácticas, técnicas, subtécnicas) y su terminología.
- 2. **Mapear** detecciones y fuentes de datos a técnicas concretas.
- 3. **Visualizar** cobertura y huecos con ATT&CK Navigator.
- 4. **Priorizar** detecciones con la pirámide del dolor de David Bianco.
- 5. **Usar** los data sources de ATT&CK para saber qué telemetría requiere cada técnica.

📖 Temas

#	Tema	Por qué importa
1	Estructura de ATT&CK	Vocabulario común de ataque
2	Tácticas vs técnicas vs procedimientos	Distintos niveles de abstracción
3	Pirámide del dolor	Qué detectar primero y por qué
4	Data sources y componentes	Qué log necesita cada técnica
5	ATT&CK Navigator	Mapa de cobertura y priorización
6	Detecciones por técnica	Del framework a reglas reales
7	Grupos y software (intel)	Amenazas relevantes para tu sector
8	Cobertura vs profundidad	No basta con "tocar" cada técnica

💬 Explicación en profundidad

ATT&CK organiza conocimiento sobre comportamientos observados, no genera reglas automáticamente. Una táctica expresa el objetivo; una técnica, el método; un procedimiento, una implementación concreta. La detección aparece al traducir un procedimiento relevante en evidencia observable dentro del entorno propio.



El mapeo baja hasta campos concretos: proceso, autenticación, conexión o cambio de servicio. Una celda coloreada debe distinguir dato disponible, analítica diseñada, prueba superada y operación sostenida. Cubrir toda la matriz sin priorización dispersa recursos; se eligen amenazas plausibles, activos críticos y capacidades de respuesta. Toda asociación con una técnica debe explicar qué variante observa y cuáles quedan fuera.

Una técnica no equivale a una detección

T1021 Remote Services reúne formas distintas de acceso remoto. RDP puede dejar autenticación y creación de sesión; SMB puede mostrar acceso a recursos y creación de servicio; WinRM produce otro recorrido. Una regla para RDP no cubre automáticamente toda T1021. El objeto de cobertura correcto combina procedimiento, activo, componente de datos y analítica.

La construcción empieza por escenarios relevantes. Si administradores usan RDP mediante un jump host, una relación directa desde una estación común tiene valor. Se necesitan origen, destino, cuenta, tipo de sesión, horario y procesos posteriores. ATT&CK ayuda a nombrar la conducta y localizar datos posibles; el entorno decide cuáles existen y qué significa anormal.

Leer una matriz sin engañarse

Una capa de Navigator necesita una leyenda. Verde puede significar fuente presente, regla desplegada o prueba superada, tres estados muy diferentes. Una evaluación útil distingue: sin dato; dato presente pero no validado; analítica diseñada; prueba positiva y negativa aprobada; operación monitoreada; capacidad degradada. Cada estado enlaza evidencia y fecha.

Las brechas también se describen. Quizá la regla vea Windows administrado pero no Linux, o detecte servicio remoto pero no credenciales reutilizadas. Registrar variantes no observadas evita que la dirección interprete un color como protección total. La prioridad no busca maximizar matriz: relaciona inteligencia de amenazas, exposición, activos críticos y coste de respuesta para decidir qué brecha reducir primero.

Del mapeo a la validación

Una prueba controlada ejecuta el procedimiento autorizado y observa cuatro capas: se generó el evento, llegó a plataforma, coincidió la analítica y el proceso respondió. Si falla la primera, no se «afina la regla»; se corrige telemetría. Si alerta pero nadie actúa, la cobertura técnica no es capacidad operativa. El mapa cambia solo después de documentar esa cadena.

Pirámide del dolor: utilidad y límites

La pirámide popularizada por David Bianco ordena tipos de indicadores según el coste que suele imponer al adversario cambiar: hashes y direcciones tienden a ser más fáciles de reemplazar que herramientas y TTPs. No es una ley cuantitativa. Una IP puede ser crítica durante una campaña activa y una regla de TTP puede ser demasiado amplia. La enseñanza es combinar señales rápidas de vida corta con analíticas conductuales más duraderas, manteniendo caducidad y pruebas.

Grupos, software e inteligencia como fuente de prioridad

Las páginas de grupos y software de ATT&CK resumen procedimientos documentados y referencias públicas. No prueban que un actor vaya a atacar a la organización ni que una técnica sea exclusiva de ese grupo. Se cruzan con sector, geografía, exposición y observaciones internas. La atribución se mantiene separada de la detección: se puede detectar una conducta sin saber quién la ejecutó.

Un perfil de amenaza útil selecciona procedimientos plausibles y activos afectados. Si varios grupos relevantes usan credenciales válidas y servicios remotos, la prioridad puede ser identidad y rutas administrativas, no una firma específica de malware. ATT&CK ofrece vocabulario para documentar la decisión; la organización aporta contexto de riesgo.

Profundidad frente a presencia

Dos detecciones mapeadas a la misma técnica pueden observar fases diferentes, usar fuentes independientes o cubrir variantes distintas. Esa redundancia puede aumentar resiliencia. En cambio, una única regla con cobertura nominal puede depender de un campo frágil. La matriz debe permitir profundidad —variedad de procedimientos, datos, plataformas y pruebas— además de presencia. Por eso el objetivo no es «una regla por técnica».

Glosario

- **Táctica:** objetivo intermedio del adversario.
- **Técnica:** método general para alcanzar un objetivo.
- **Subtécnica:** variante específica.
- **Procedimiento:** implementación observada.
- **Componente de datos:** actividad concreta observable.
- **Estrategia de detección:** enfoque para reconocer comportamiento.
- **Cobertura validada:** datos, analítica y prueba reproducible.

Definiciones y características

- **Táctica:** el "por qué" del adversario (Ejecución, Persistencia, Exfiltración). Característica: 14 categorías que forman las columnas de la matriz.
- **Técnica:** el "cómo" (T1059 Command and Scripting Interpreter). Característica: puede tener subtécnicas (T1059.001 PowerShell).
- **Procedimiento:** la implementación concreta que usa un grupo. Característica: el nivel más específico y variable.
- **Pirámide del dolor:** modelo que ordena los indicadores por lo difícil que es para el atacante cambiarlos (hash < IP < dominio < artefactos < herramientas < TTPs). Característica: detectar arriba de la pirámide causa más "dolor".
- **Data source (ATT&CK):** tipo de telemetría necesaria para detectar una técnica (Process Creation, Network Traffic). Característica: guía tu estrategia de logging.
- **ATT&CK Navigator:** herramienta web para colorear la matriz según cobertura o intel. Característica: comunica huecos visualmente.

Cobertura resuelta — Remote Services

Se prioriza T1021 porque los administradores usan un bastión y los accesos directos a servidores críticos no están autorizados. En vez de colorear toda la técnica, se descompone:

Procedimiento	Evidencia necesaria	Estado de ejemplo
RDP directo	autenticación, origen, destino, sesión/proceso	probado en Windows
SMB/admin share	acceso a share, escritura, servicio/proceso	analítica en prueba
WinRM	autenticación, servicio y proceso host	dato presente, sin regla
SSH	autenticación y comando/sesión en Linux	sin cobertura en segmento legado

La capa Navigator puede mostrar estos resultados agregados, pero enlaza la ficha de evidencia. Probar RDP no autoriza marcar WinRM o SSH. El estado «dato presente» tampoco significa que un analista recibirá una alerta.

La priorización se justifica por amenaza, exposición y activo. Si el entorno no usa RDP, invertir primero en esa variante tendría poco sentido aunque ATT&CK la documente. La matriz es una representación de decisiones propias, no una lista obligatoria de todas las técnicas.

✓ Criterio de dominio

El alumno puede bajar de táctica a procedimiento, componentes y campos, ejecutar una prueba autorizada y describir brechas. El porcentaje de celdas coloreadas no es un resultado aceptable sin significado y evidencia.

🧰 Herramientas y preparación

- **ATT&CK Navigator** (versión web oficial o desplegada localmente).
- El **STIX/JSON de ATT&CK** para automatizar mapeos si lo deseas.
- Tus reglas Sigma de la clase 186 (ya traen tags `attack.tXXXX`).
- **DeTT&CT** o **Atomic Red Team** para razonar sobre cobertura y validación (Atomic se usará en profundidad en la clase 200).

Cualquier ejecución de técnicas para validar se hace en el laboratorio propio.

🔧 Laboratorio guiado — Mapa de cobertura de detección

1. **Inventaria tus detecciones.** Lista tus reglas Sigma/SIEM y anota el `attack.tXXXX` de cada una.
2. **Carga Navigator.** Abre ATT&CK Navigator y crea una capa nueva.
3. **Colorea cobertura.** Marca en verde las técnicas que tus reglas cubren; en rojo las críticas sin cobertura.
4. **Cruza con tus fuentes.** Para 5 técnicas rojas, revisa su *data source* en ATT&CK y verifica si ya recolectas esa telemetría (clase 182).
5. **Aplica la pirámide del dolor.** Clasifica 10 de tus detecciones: ¿detectas por hash/IP (base) o por comportamiento/TTP (cima)? Prioriza subir de nivel.
6. **Prioriza con intel.** Elige un grupo relevante para tu sector (p. ej. de la página de Groups de ATT&CK) y superpón sus técnicas: cubre primero las que ese grupo usa.
7. **Documenta huecos.** Genera un plan: 5 técnicas sin cobertura, la telemetría que faltaría y la detección propuesta.

Ejercicios

1. Clasifica 6 indicadores en su nivel de la pirámide del dolor.
2. Elige una técnica (p. ej. T1053 Scheduled Task) y lista su data source y una detección.
3. Crea una capa de Navigator con la cobertura real de tu laboratorio.
4. Explica por qué detectar por hash es frágil con un ejemplo concreto.
5. Mapea un ataque de la Parte 7 (red team) a una cadena de técnicas ATT&CK.
6. Propón cómo pasarías una detección de nivel IP a nivel TTP.

Reto verificable

Entrega una capa de ATT&CK Navigator que refleje la cobertura de detección de tu laboratorio y un plan priorizado de 5 huecos a cerrar, cada uno con su data source y detección propuesta. **Criterio de aceptación:** la capa distingue claramente técnicas cubiertas y no cubiertas, y para cada hueco justificas la prioridad usando la pirámide del dolor y/o la relevancia de un grupo de amenaza concreto.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Cubrimos el 90% de ATT&CK"	Confundes tocar la técnica con detectarla bien; mide profundidad, no solo presencia
Detecciones solo por IOC	Estás en la base de la pirámide; migra a comportamiento
Técnica marcada verde sin telemetría	No hay data source que la respalde; revisa fuentes reales
Navigator saturado de colores	Falta priorización; filtra por intel relevante
Subtécnicas ignoradas	Mapeas solo a la técnica padre; baja al nivel de subtécnica

Preguntas frecuentes

? ¿Debo intentar cubrir toda la matriz? No. Prioriza por amenazas reales de tu sector y por profundidad. Cien técnicas mal cubiertas valen menos que veinte detectadas con solidez.

? ¿ATT&CK sustituye a la Cyber Kill Chain? No compiten. La Kill Chain describe fases de alto nivel; ATT&CK detalla el "cómo" con técnicas concretas. Muchos equipos usan ambas.

? ¿Cobertura de Navigator = seguridad? Es un mapa, no una garantía. Una técnica en verde puede tener una regla frágil o llena de falsos positivos. Valídala (clase 200, purple team).

Referencias verificables y alcance

- MITRE ATT&CK: base de conocimiento primaria para tácticas, técnicas, subtécnicas, grupos, software y procedimientos — <https://attack.mitre.org/>
- MITRE ATT&CK Detection Strategies: contenido oficial que vincula estrategias, analíticas y componentes de datos; no certifica la cobertura de un entorno — <https://attack.mitre.org/detectionstrategies/>

- MITRE, detecciones y analíticas: guía oficial para interpretar el modelo de detección — <https://attack.mitre.org/resources/get-started/detections-and-analytics/>
- ATT&CK Data Components: propiedades observables asociadas a comportamientos; deben traducirse a campos y fuentes concretas del despliegue — <https://attack.mitre.org/datacomponents/>
- ATT&CK Navigator: herramienta oficial para crear capas y visualizar decisiones de cobertura; el color de una celda no es evidencia de eficacia — <https://mitre-attack.github.io/attack-navigator/>
- Bianco, D. "The Pyramid of Pain": fuente original del modelo conceptual; se usa como heurística de coste para el adversario, no como ley de priorización — <http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- DeTT&CT: herramienta comunitaria para administrar cobertura y visibilidad; complementa, pero no sustituye, pruebas locales — <https://github.com/rabobank-cdc/DeTTECT>



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

Clase 186 — Escritura de reglas de detección con Sigma



Siguiente clase

Clase 188 — Threat hunting: metodología